

PLANTILLA DE REPORTE EJECUTIVO

Programa de Indicadores GQM+PRAGMATIC para OWASP SAMM

Versión: 1.0 | **Fecha:** Enero 2026

Formato: Guía de estructura PowerPoint para Comité de Dirección y Board

Duración recomendada: 30-45 minutos de presentación + Q&A

ESTRUCTURA DEL DECK POWERPOINT (14 Diapositivas)

SLIDE 1 — PORTADA

Contenido visual

Título Principal (44pt, bold):

PROGRAMA DE MÉTRICAS DE CIBERSEGURIDAD
GQM + PRAGMATIC + OWASP SAMM

Subtítulo (28pt):

Evaluación de Madurez y ROI de Iniciativas de Seguridad

Pie de página:

- Logo de organización (parte superior izquierda)
- Nombre CISO / Director de Seguridad
- Fecha: Enero 2026
- Clasificación: [Internal / Confidential / etc.]

Notas para el ponente

"Buenos días. Hoy comparto nuestro programa integral de métricas de ciberseguridad. Este no es un reporte más de números; es la base para decisiones de inversión informadas y demostración de cumplimiento regulatorio."

SLIDE 2 — AGENDA

Contenido

Viñetas (6 puntos principales, 28pt):

1. ✓ Contexto regulatorio: Por qué necesitamos métricas ahora
2. ✓ Marco GQM+PRAGMATIC+SAMM: Cómo conectamos regulación con datos técnicos
3. ✓ Resultados clave: Dónde estamos hoy (IGM actual)
4. ✓ Riesgos y brechas: Qué debemos mejorar
5. ✓ Caso de negocio: ROI de las iniciativas propuestas
6. ✓ Roadmap 12 meses: Hoja de ruta de mejora

Visual

Iconos pequeños a la izquierda de cada bullet.

SLIDE 3 — CONTEXTO Y OBLIGACIONES REGULATORIAS

Título

Por qué necesitamos un programa integral de métricas

Contenido principal

Left column — Normativa obligatoria (2 min read):

- NIS2 (Directiva UE 2022/2555)
- Entrada vigencia: Ene 2023 | Transposición: Oct 2024
- Aplica a: Operadores esenciales e importantes
- Exige: Gestión de riesgos, medidas técnicas, incident response

• Art. 21: "medidas continuas y proporcionales"

- CRA (Cyber Resilience Act)

- Entrada vigencia: Dic 2024 | Conformidad técnica: Sept 2026
- Aplica a: Proveedores de productos digitales (software, IoT, etc.)
- Exige: Secure by design, eliminación de vulnerabilidades conocidas, gestión de ciclo de vida

• Art. 10: "sin vulnerabilidades explotables conocidas"

- GDPR (Reglamento UE 2016/679)

- Art. 25: Privacy by design

- Art. 32: Medidas técnicas y organizativas de seguridad

- ENS (Esquema Nacional de Seguridad)

- Aplica a: Administración Pública española

- Principios: Confidencialidad, Integridad, Disponibilidad

- DORA (Digital Operational Resilience Act)

- Aplica a: Sector financiero europeo
- Art. 16: Gestión de riesgos TIC
- Art. 17: Incident reporting

Art. 21: "medidas continuas y proporcionales"

CRA (Cyber Resilience Act)

Art. 10: "sin vulnerabilidades explotables conocidas"

GDPR (Reglamento UE 2016/679)

Art. 32: Medidas técnicas y organizativas de seguridad

ENS (Esquema Nacional de Seguridad)

Principios: Confidencialidad, Integridad, Disponibilidad

DORA (Digital Operational Resilience Act)

Right column — Implicaciones para nosotros:

Normativa	Riesgo Principal	Implicación
NIS2	Sanciones; operaciones interrumpidas	Demostrar medidas técnicas + procesos
CRA	Product recalls; sanciones	Eliminar vulns antes de release
GDPR	Multas hasta €20M	Proteger datos personales
ENS	Auditoría / exclusión de contratación	Cumplir estándares de entidad pública
DORA	Retiro de licencia (finanzas)	Resiliencia operacional garantizada

Visual sugerido

- Timeline horizontal: 2024-2026 con hitos de cumplimiento
- Iconos por norma (NIS2=🛡️, CRA=⚙️, GDPR=🔒, ENS=🏛️, DORA=💰)

SLIDE 4 — MARCO QM+PRAGMATIC+SAMM

Título

Cómo conectamos regulación con datos técnicos

Contenido principal

Diagrama 4 niveles (visual central, 60% de la diapositiva):

NIVEL 0: OBJETIVO NACIONAL

- Regulación: NIS2 Art. 21, CRA Annex I, etc.
- Ejemplo: "Detectar incidentes en <4h"

↓

NIVEL 1: GQM GOAL (Objetivo específico)

- Statement: "Mejorar velocidad de detección operativa"
- Métrica: Mejorar MTDD a <4h

↓

NIVEL 2: GQM QUESTIONS (Preguntas operacionales)

- Q1: "¿Cuál es el MTDD promedio? (mean, median, P95)"
- Q2: "¿% de detecciones son automáticas?"
- Q3: "¿Cuáles son causas raíz de retrasos?"

↓

NIVEL 3: MÉTRICAS TÉCNICAS (Datos cuantificables)

- M1: MTDD Mean = 12 horas (ACTUAL)
- M2: MTDD Median = 8 horas
- M3: MTDD P95 = 48 horas
- M4: Autonomous Detection = 65%

Bottom section — Criterios PRAGMATIC

9 criterios de calidad de métricas (matriz pequeña):

P	R	A	G	M	A	T	I	C
Predictivo	Relevante	Accionable	Genuino	Significativo	Medible	Oportuno	Independiente	Rentable
¿Predice riesgo futuro?	¿Importante a stakeholders?	¿Permite decisiones?	¿Refleja realidad?	¿Significativo?	¿Medible?	¿Disponible a tiempo?	¿Auto-interpretable?	¿Costo razonable?

Notas para el ponente

"El marco GQM+PRAGMATIC no es nuevo; lo usan NASA y Harvard desde hace 25 años. Hemos adaptado estas metodologías probadas a nuestro contexto de ciberseguridad española."

SLIDE 5 — DOMINIO SAMM Y COBERTURA

Título

Coertura de indicadores por dominio SAMM v2

Contenido visual

Gráfico de radar o tabla con 6 dominios:

Dominio	# Métricas	# Implementadas	% Cobertura	Status
Gobernanza	4	2	50%	
Diseño	3	2	67%	
Implementación	4	4	100%	
Verificación	4	2	50%	
Operaciones	7	5	71%	
Capacitación	4	1	25%	

Interpretación

"Vemos fortaleza en Implementación (100% cobertura) gracias a nuestra madurez en DevSecOps. Pero tenemos brechas significativas en Capacitación (25%) y Gobernanza (50%). Esto refleja donde debemos enfocar inversión."

SLIDE 6 — TOP 10 MÉTRICAS (RANKING PRAGMATIC)

Título

Las 10 métricas con mejor calidad (Score PRAGMATIC)

Contenido

Tabla horizontal con 10 filas (20pt letra):

Rank	Métrica	Dominio	PRAGMATIC Score	Nivel Prioridad
	SAST Integration Coverage	IMP	95.6%	★★★★
	EPSS Score Adoption	VULN	93.3%	★★★★
	MTTD Mean	OPS	91.1%	★★★★
4	Threat Model Coverage	DES	88.9%	★★★
5	MTTR Critical	OPS	88.9%	★★★
6	Pre-Prod Vuln Closure	IMP	88.9%	★★★
7	Patch Compliance	OPS	88.9%	★★★
8	KPI Tracking Coverage	GOV	88.9%	★★★
9	Phishing Click Rate	TRAIN	86.7%	★★★
10	Strategy Documentation	GOV	86.7%	★★★

Interpretación

"No todas las métricas valen lo mismo. Las primeras 3 (SAST, EPSS, MTTD) tienen scores PRAGMATIC >90%, lo que significa que son altamente predictivas, accionables y medibles. Estas son nuestras 'quick wins'."

SLIDE 7 — ÍNDICE GLOBAL DE MADUREZ (IGM)

Título

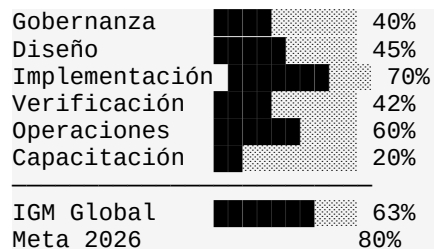
Nuestra foto actual de madurez de seguridad

Contenido visual

Central: Número grande IGM:

IGM = 63 / 100
(63% Madurez)

Gráfico de barras horizontal (60% de diapositiva):



Interpretación

"Estamos en 63/100. Nuestra meta para 2026 es 80 (línea azul). Esto representa 17 puntos adicionales de madurez, alcanzable con las iniciativas que proponemos hoy."

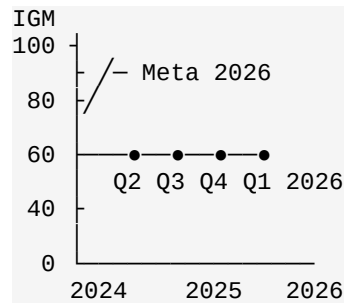
SLIDE 8 — EVOLUCIÓN IGM (Histórico si existe)

Título

Progreso de madurez (últimos 12-24 meses)

Contenido visual

Gráfico de línea con tendencia:



Anotaciones sobre la línea

- Q2 2024: "IGM 50" — Baseline establecida
- Q4 2024: "IGM 58" — Post SAST integration
- Q1 2025: "IGM 63" — Post SIEM improvement + formación
- Q4 2026 (goal): "IGM 80" — Full program deployment

Notas para el ponente

"Hemos crecido 13 puntos en 12 meses (50–63). A este ritmo, alcanzamos 80 en otros 12-18 meses, asumiendo inversión sostenida."

SLIDE 9 — RIESGOS Y BRECHAS CLAVE

Título

Riesgos identificados y brecha a regulación

Contenido

5 brechas críticas (formato: Brecha | Riesgo | Normativa | Acción):

7. MTTD > 12h (objetivo: <4h)
8. Riesgo: Exposición prolongada; incidentes no contenidos
9. Normativa: NIS2 Art. 21.2(b)(c); DORA Art. 16
10. Acción: Inversión SIEM + ML rules + SOC hire
11. Threat Modeling Coverage 50% (objetivo: 90%)
12. Riesgo: Vulnerabilidades de diseño detectadas post-producción
13. Normativa: CRA "Secure by Design" (Art. 10)
14. Acción: Training arquitectos; herramientas modeling
15. Phishing Click-Rate 12% (objetivo: <5%)
16. Riesgo: Incidentes por phishing no prevenibles
17. Normativa: NIS2 Art. 21.2(g); GDPR Art. 32
18. Acción: Programa formación intensivo; simulaciones mensuales
19. Capacitación completada 75% (objetivo: 95%+)
20. Riesgo: Empleados sin sensibilización en riesgos
21. Normativa: NIS2 Art. 21.2(g); GDPR Art. 32
22. Acción: Automatizar recordatorios; gamificación
23. Gobernanza débil (Strategy review 1x/año)
24. Riesgo: Desalineación entre negocio y seguridad
25. Normativa: NIS2 Art. 20 (governance); CRA (alineación)
26. Acción: Revisar estrategia 2x/año; comunicación trimestral

Acción: Inversión SIEM + ML rules + SOC hire

Threat Modeling Coverage 50% (objetivo: 90%)

Acción: Training arquitectos; herramientas modeling

Phishing Click-Rate 12% (objetivo: <5%)

Acción: Programa formación intensivo; simulaciones mensuales

Capacitación completada 75% (objetivo: 95%+)

Acción: Automatizar recordatorios; gamificación

Gobernanza débil (Strategy review 1x/año)

Visual

Cada brecha con "semáforo"  /  /  de urgencia.

SLIDE 10 — CASO DE NEGOCIO Y ROI

Título

ROI de iniciativas propuestas (3 años)

Contenido

Tabla con iniciativas prioritarias:

Iniciativa	Coste Total (€)	Beneficio Anual (€)	Ahorro 3 años (€)	ROI (%)	Payback (años)	ΔIGM
1. SAST en CI/CD	75k	35k	105k	40%	2.1	+5
2. SIEM + ML Rules	135k	60k	180k	33%	2.3	+8
3. Red Team + Pentesting	50k	25k	75k	50%	2.0	+4
4. Formación intensiva	30k	15k	45k	50%	2.0	+3
5. Threat Modeling Tools	20k	10k	30k	50%	2.0	+3
TOTAL PROGRAMA	310k	145k	435k	40%	2.1	+23

Interpretación

"Invertimos €310k en 3 años (€103k/año promedio). Recuperamos esa inversión en 2.1 años. El beneficio calculado es conservador (solo costo de incidentes evitados). Además, mejoramos IGM en +23 puntos (63–86), superando meta de 80."

Visual gráfico

- Columna del lado izquierdo: Coste (€310k en rojo)
- Columna central: Beneficio acumulado 3 años (€435k en verde)
- Diferencia: +€125k neto (en azul)

SLIDE 11 — ROADMAP 12-18 MESES

Título

Plan de ejecución por trimestre

Contenido visual

Timeline horizontal con 4 trimestres:

Q1 2026	Q2 2026	Q3 2026	Q4 2026
QUICK WINS - SAST CI/CD - MTTD SIEM - Phishing - Scan cov. - Budget: €10k - Effort: 0.5 5 metrics	CONSOLIDATION - Threat modeling - MTTR SLA track - Patch mgmt - Pentesting Q2 - Budget: €15k - Effort: 1 FTE +4 metrics	EXPANSION - EPSS feed - SIEM tune - Red team - Capac. - Budget: €25k - Effort: 1.5 +6 metrics	OPTIMIZATION - Governance KPIs - Annual review - Optimization - Next phase plan - Budget: €20k - Effort: 1 FTE - Governance

Tabla resumen por trimestre

Trimestre	Objetivo IGM	# Iniciativas	Presupuesto	Métricas Implementadas
Q1 2026	65	5	€10k	SAST, MTTD, Phishing, Scan, Build gates
Q2 2026	69	4	€15k	Threat models, MTTR, Patch, Pentesting
Q3 2026	76	6	€25k	EPSS, SIEM tuning, Red team, formación avanzada
Q4 2026	80+	3	€20k	Governance KPIs, documentación, roadmap 2027

SLIDE 12 — MENSAJES CLAVE AL BOARD

Título

Lo que necesita saber el Consejo

Contenido (3-4 bullets grandes, 32pt)

- ✓ **"Pasamos de percepciones a métricas trazables"**
 - Cada indicador se conecta directamente a NIS2, CRA, GDPR, ENS, DORA
 - Auditable, defendible, reproducible
 - Comunicamos con datos, no con opiniones
- ✓ **"Sabemos exactamente dónde estamos y qué nos falta"**
 - IGM Actual: 63/100
 - Meta 2026: 80/100
 - Brecha: 17 puntos (alcanzable con roadmap propuesto)
- ✓ **"Cada euro invertido genera retorno medible"**
 - ROI promedio: 40% en 3 años
 - Payback: 2.1 años
 - Además: +23 puntos IGM (hacia cumplimiento regulatorio)
- ✓ **"El programa es realista, incremental, pragmático"**
 - Quick wins en Q1 (3 semanas, €10k)
 - Escalable; no requiere transformación radical
 - Alineado con capacidad operativa actual

SLIDE 13 — PRÓXIMOS PASOS (30-90 DÍAS)

Título

Acciones inmediatas (por responsable)

Contenido

Responsable	Acción	Fecha	Deliverable
CISO	Validar top 5 métricas con propietarios	1 feb	Lista de owners
DevSecOps	Implementar SAST en CI/CD (Q1 Quick Win)	15 mar	SAST activo 80%+ apps
SOC Manager	Configurar alertas MTTD en SIEM	15 mar	Dashboard MTTD activo
Security Awareness	Lanzar programa simulación phishing	1 feb	Primera simulación
Gobernanza	Establecer comité de métricas	15 feb	Reunión 1ª sesión
CFO	Liberar presupuesto Q1 (€10k)	31 ene	Fondos comprometidos

Próxima reunión de seguimiento

- Fecha: 28 Febrero 2026
- Agenda: Validación de progreso Q1; ajustes roadmap si es necesario

SLIDE 14 — CIERRE Y CONTACTO

Título

Preguntas y Discusión

Contenido

Resumen ejecutivo 1-slide (recapitulación visual):

- IGM Actual: 63/100 | Meta 2026: 80/100
- Regulación: NIS2, CRA, GDPR, ENS, DORA (España 2026)
- ROI: 40% en 3 años; payback 2.1 años
- Roadmap: Q1 Quick Wins (€10k) → Q2-Q4 Consolidation/Expansion (€300k adicional)
- Próximo checkpoint: 28 Feb 2026

Contacto:

- CISO: [Nombre] | ciso@org.com
- Measurement Lead: [Nombre] | measurement@org.com

Documentación adjunta:

- Marco integrativo GQM+PRAGMATIC.pdf
- Matriz de evaluación PRAGMATIC.xlsx
- Excel de cálculo IGM/ROI (en construcción)

NOTAS ADICIONALES PARA EL PONENTE

Timing recomendado

- Slide 1-2: 2 min (contexto)
- Slide 3: 5 min (normativa + urgencia)
- Slide 4-5: 5 min (marco técnico)
- Slide 6-7: 3 min (dónde estamos)
- Slide 8-9: 5 min (riesgos)
- Slide 10: 8 min (caso de negocio ROI)
- Slide 11-13: 7 min (roadmap, acciones)
- Slide 14: 3 min (cierre)
- Q&A: 10 min

Total: 45-50 minutos

Anticipar preguntas

P: "¿Por qué necesitamos esto si ya tenemos firewall y antivirus?"

A: "Firewall y antivirus son controles externos. NIS2/CRA exigen demostrar seguridad desde diseño, en desarrollo y operaciones. Las métricas nos permiten evidenciar todo el ciclo de vida."

P: "¿No es demasiado costoso (€310k en 3 años)?"

A: "Costo de un incidente medio (breach de datos, indisponibilidad 1 hora): €500k+. Una sola prevención recupera la inversión."

P: "¿Cuándo vemos ROI?"

A: "Payback es 2.1 años. Pero beneficios cualitativos (compliance, reducción riesgo reputacional) son inmediatos."

Apoyos visuales recomendados

- Video de 2 min (case study de incidente externo evitable con mejor MTDD)
- Demo del dashboard IGM en vivo (si es posible)
- Comparativa con benchmarks de industria (si tienes datos)